

BÀI GIẢNG AN TOÀN & BẢO MẬT THÔNG TIN

CHƯƠNG 6 - QUẢN LÝ KHOÁ

TS. NGUYỄN ĐÌNH DƯƠNG
BỘ MÔN KHMT - KHOA CÔNG NGHỆ THÔNG TIN

Email: duongnd@utc.edu.vn

Ngày 03/07/2022

Nội dung

Quản lí khoá

- 1.1 Mở đầu
- 1.2 Sơ đồ phân phối khoá Blom
- 1.3 Sơ đồ phân phối khoá Kerberos
- 1.4 Hệ phân phối khoá Diffie-Hellman
- 1.5 Giao thức trao đổi khoá Matsumoto-Takashima-Imai
- 1.6 Giao thức Girault trao đổi khoá không chứng chỉ

Trao đổi

Nội dung

Quản lý khoá

- 1.1 Mở đầu
- 1.2 Sơ đồ phân phối khoá Blom
- 1.3 Sơ đồ phân phối khoá Kerberos
- 1.4 Hệ phân phối khoá Diffie-Hellman
- 1.5 Giao thức trao đổi khoá Matsumoto-Takashima-Imai
- 1.6 Giao thức Girault trao đổi khoá không chứng chỉ

Trao đổi

1. Quản lý khoá

1. 1. Mở đầu

- Các hệ mã khoá đối xứng cần những kênh bí mật để chuyển khoá hoặc trao đổi khoá giữa các đối tác.
- Các hệ mã khoá công khai về nguyên tắc không cần những kênh bí mật vì khoá có thể được truyền hay trao đổi qua các kênh công cộng.
- Thực tế, không phải bất cứ thông tin nào về khoá công khai của một hệ mã, thuật toán kiểm tra chữ kí, giao thức xác nhận thông báo, ... cũng được phát tràn lan trên mạng công cộng (chỉ những ai cần biết thì nên biết) → giao thức trao đổi khoá giữa các đối tác thực sự có nhu cầu.
- Trong một cộng đồng:
 - việc trao đổi khoá thiết lập một cách tự do giữa bất kì 2 người nào → **thoả thuận khoá**
 - việc trao đổi khoá thiết lập tương đối lâu dài với sự điều phối của một cơ quan được uỷ thác TA → **phân phối khoá**

1. Quản lý khoá

1. 2. Sơ đồ phân phối khoá Blom

- Giả sử một mạng gồm có n users:
 - TA quản lý $\frac{n(n-1)}{2}$ khoá
 - TA phải chuyển cho mỗi user $n-1$ khoá chung với $n-1$ users còn lại $\rightarrow$ TA cần truyền qua kênh bí mật $n(n-1)$ lượt khoá
- Năm 1985, Blom đề xuất sơ đồ phân phối khoá sau:
 - TA chọn 1 số nguyên tố $p \geq n$ và cho mỗi người dùng A một số $r_A \in \{0, 1, \dots, p-1\}$ (p và r_A được công khai)
 - TA chọn 3 số ngẫu nhiên $a, b, c < p$ và lập đa thức $f(x, y) = a + b(x + y) + cxy \mod p$
 - Với mỗi người dùng A, TA tính $g_A = f(x, r_A) = a_A + b_A x \mod p$, trong đó
$$\begin{cases} a_A = a + br_A \mod p \\ b_A = b + cr_A \mod p \end{cases}$$
 - TA chuyển bí mật (a_A, b_A) cho A
- TA chỉ phải truyền n lượt các cặp số (a_A, b_A) mà thôi !!!
- Alice và Bob tạo khoá chung: $K_{AB} = g_A(r_B) = g_B(r_A) = f(r_A, r_B)$

1. Quản lý khoá

1. 2. Sơ đồ phân phối khoá Blom

Độ an toàn của sơ đồ Blom

- Người thứ ba C (kể cả C là người tham gia trong mạng) không thể biết được khoá bí mật của A và B:

- nếu C tham gia mạng thì C biết (a_C, b_C)

- với mọi $\ell \in \{0, 1, \dots, p-1\}$

$$\begin{cases} a + b(r_A + r_B) + cr_Ar_B &= \ell \\ a + br_C &= a_C \text{ luôn có nghiệm} \rightarrow \ell \text{ là } K_{AB} \\ b + cr_C &= b_C \end{cases}$$

- Tuy nhiên, nếu có hai người C và D liên minh với nhau thì K_{AB} rất dễ bị phát hiện

$$\begin{cases} a + br_C &= a_C \\ b + cr_C &= b_C \\ a + br_D &= a_D \\ b + cr_D &= b_D \end{cases} \rightarrow (a, b, c) \rightarrow K_{AB}$$

1. Quản lý khoá

1. 3. Sơ đồ phân phối khoá Kerberos

- Kerberos cung cấp khoá cho từng phiên truyền tin bảo mật theo yêu cầu của người dùng trong một mạng truyền tin (session key): DES, AES
- $ID(A)$ là kí hiệu định danh của người dùng A trong mạng (công khai)
- TA chia sẻ khoá bí mật K_A với mỗi thành viên A trong mạng. Mỗi khi A có nhu cầu truyền tin bảo mật với B thì yêu cầu TA cấp một khoá phiên K cho cả A và B:
 - TA chọn ngẫu nhiên khoá K , xác định tem thời gian T và thời gian sống L (K chỉ được sử dụng trong khoảng $T \rightarrow T + L$)
 - TA tính $m_1 = e_{K_A}(K, ID(B), T, L)$, $m_2 = e_{K_B}(K, ID(A), T, L)$ và gửi (m_1, m_2) đến A.
 - A dùng hàm giải mã d_{K_A} cho m_1 để thu được $K, T, L, ID(B)$. Sau đó tính $m_3 = e_K(ID(A), T)$, và gửi (m_3, m_2) cho B.
 - B dùng các hàm giải mã d_{K_B} cho m_2 và d_K cho m_3 để thu được $K, T, L, ID(A)$ và $ID(A)$, T . Nếu thấy hai giá trị $ID(A)$ và T trùng nhau thì B tính tiếp $m_4 = e_K(T + 1)$ gửi cho A
 - A dùng hàm giải mã d_K cho m_4 và xem kết quả thu được có đúng là $T + 1$ hay không?

1. Quản lý khoá

1. 3. Sơ đồ phân phối khoá Kerberos

Độ an toàn của sơ đồ Kerberos

- 5 bước trong giao thức cấp phát khoá Kerberos đều được thực hiện trên kênh công cộng
- Ngoài ra, giao thức còn thực hiện việc xác thực khoá:
 - A và B đều tin chắc rằng đối tác của mình đã thực sự có khoá K do kết quả ở bước 4 và 5
 - A và B đều biết được thời hạn có hiệu lực của khoá.
- Sơ đồ phân phối khoá Kerberos có độ tin cậy cao nhưng việc thực hiện tốn nhiều thời gian → ít được phổ biến rộng rãi

1. Quản lí khoá

1. 4. Hệ phân phối khoá Diffie-Hellman

- Hệ phân phối khoá Diffie-Hellman không đòi hỏi TA phải biết và chuyển bất kì thông tin mật nào về khoá của users trong mạng
- TA chỉ cần chọn một số nguyên tố lớn p và căn nguyên thuỷ α theo $\text{mod } p$ (công khai)
- TA có một sơ đồ chữ kí: $\text{sig}_{\text{TA}} + \text{ver}_{\text{TA}}$
- A chọn số a_A ($0 \leq a_A \leq p - 2$) và tính $b_A = \alpha^{a_A} \text{ mod } p$
- A giữ bí mật a_A và đăng kí các thông tin $(ID(A), b_A)$ để TA cấp cho A chứng chỉ

$$C(A) = (ID(A), b_A, \text{sig}_{\text{TA}}(ID(A), b_A))$$

- Các chứng chỉ này có thể lưu giữ trong một cơ sở dữ liệu công khai hoặc uỷ thác cho TA lưu giữ

1. Quản lý khoá

1. 4. Hệ phân phối khoá Diffie-Hellman

- Khi A và B cần có khoá bí mật chung để truyền tin:
 - A dùng thông tin công khai b_B trong $C(B)$ để tạo khoá $K_{AB} = b_B^{a_A} \mod p = \alpha^{a_A a_B} \mod p$
 - B cũng dùng thông tin công khai b_A trong $C(A)$ để tạo khoá $K_{AB} = b_A^{b_B} \mod p = \alpha^{a_A a_B} \mod p$
- Để đảm bảo b_A, b_B là chính xác, A và B có thể dùng thuật toán ver_{TA} để kiểm tra chữ kí xác nhận của TA trong $C(B), C(A)$

⊕ Nhận xét:

- Trong hệ phân phối khoá Diffie-Hellman, vai trò của TA là rất yếu: chỉ làm mỗi việc cấp chứng chỉ xác nhận khoá công khai cho từng người dùng
- Muốn thông tin liên quan đến việc tạo khoá thì người dùng sẽ trao đổi trực tiếp với nhau → TA chỉ tham gia kiểm thử chữ kí người dùng.

1. Quản lý khoá

1. 4. Hệ phân phối khoá Diffie-Hellman

- Chứng chỉ TA cấp cho người dùng A là

$$C(A) = (ID(A), \text{sig}_A, \text{sig}_{TA}(ID(A), \text{ver}_A))$$

- Việc trao đổi khoá bao gồm:

- A chọn số a_A ($0 \leq a_A \leq p-2$), tính $b_A = \alpha^{a_A} \bmod p$ và gửi b_A cho B

- B chọn số a_B ($0 \leq a_B \leq p-2$), tính $b_B = \alpha^{a_B} \bmod p$, tính tiếp $\begin{cases} K = b_A^{a_B} \bmod p \\ y_B = \text{sig}_B(b_B, b_A) \end{cases}$ và

gửi $(C(A), b_B, y_B)$ cho A

- A tính $K = b_B^{a_A} \bmod p$, dùng ver_{TA} để kiểm thử $C(B)$, sau đó tính $y_A = \text{sig}_A(b_A, b_B)$

và gửi $(C(A), y_A)$ cho B

- B dùng ver_A để kiểm thử y_A và ver_{TA} để kiểm thử $C(A)$

Nội dung

Quản lý khoá

- 1.1 Mở đầu
- 1.2 Sơ đồ phân phối khoá Blom
- 1.3 Sơ đồ phân phối khoá Kerberos
- 1.4 Hệ phân phối khoá Diffie-Hellman
- 1.5 Giao thức trao đổi khoá Matsumoto-Takashima-Imai
- 1.6 Giao thức Girault trao đổi khoá không chứng chỉ

Trao đổi

TRAO ĐỔI